



SOMAIYA

VIDYAVIHAR UNIVERSITY
K J Somaiya School of Engineering
(formerly K J Somaiya College of Engineering)



CSFCL-IA2 • CYBER SECURITY FORENSICS & COMPLIANCE LAWS

The Equifax breach of 2017, examined with Trivy

An examination of reconstructed application evidence linked to a breach affecting approximately 147 million people, with an academic comparison to Indian law.

Yashasvi Gupta (16010123341)

Shubhpreet Kaur (16010123328)

Shweta Karandikar (16010123329)

Dept. of Computer Engineering

01 • THE CASE

The Equifax breach: 147 million people affected

Equifax is one of the three major US credit bureaus, similar in role to CIBIL in India. Attackers entered its ACIS consumer dispute portal through CVE-2017-5638, a known Apache Struts vulnerability. A fix had been available for 67 days before the main intrusion.

≈147M

People affected; exposed information included names, Social Security numbers and dates of birth

67 days

Between the public fix and the main intrusion

76 days

Undetected access reported by official investigations

Up to \$700M

US settlement announced in 2019, including consumer relief and penalties



02 • THE TIMELINE

The timeline and missed opportunities

Date in 2017	What happened
7 March	Apache announces the vulnerability and releases fixes
9 March	Equifax circulates a patch alert to about 430 recipients and mailing lists, with a 48-hour deadline
15 March	Scans covering 958 internet-facing addresses fail to identify the exposure
13 May	Main intrusion begins
29 July	Certificate maintenance restores visibility and suspicious traffic appears
30 July	Equifax shuts down the portal
7 September	Equifax publicly announces the breach

The fix was available **67 days** before the main intrusion.



03 • THE LOSS

How the breach expanded

Plaintext credentials allowed access far beyond the portal's needs.

$$\begin{array}{ccccc} \mathbf{3 \text{ databases}} & + & \mathbf{48 \text{ additional}} & = & \mathbf{51 \text{ in total}} \\ \text{Required by ACIS} & & \text{Accessible through exposed} & & \text{Total database reach} \\ & & \text{credentials} & & \end{array}$$

≈30

Web shells

Attackers used about 30 web shells to maintain access.

≈9,000

Database queries

265 returned personal information.

67

Replacement certificates

Uploading them helped restore monitoring visibility.



Data exposure, consequences and our examination

Data exposure and consequences

Data category	US consumers (approx.)
Social Security numbers	145.5 million
Dates of birth	146.6 million
Addresses	99 million
Payment card details	209,000
Uploaded dispute documents	182,000

Categories overlap; do not add these figures.

2019 US settlement: at least \$575 million, potentially \$700 million

2018 UK ICO fine: £500,000

2023 UK FCA fine: £11,164,400

Trivy 0.74.0: read-only, repeatable, free



What Trivy checks	Command examples
Identification: known CVEs	<code>trivy rootfs --scanners vuln</code>
Identification: software inventory (SBOM)	<code>trivy rootfs --format cyclonedx</code>
Data governance: passwords and keys	<code>trivy fs --scanners secret</code>
Configuration: unsafe settings	<code>trivy fs --scanners misconfig</code>

Command examples shown; target paths and project options are supplied by the investigation script.



SOMAIYA

VIDYAVIHAR UNIVERSITY

K J Somaiya School of Engineering

(formerly K J Somaiya College of Engineering)



05 • THE INVESTIGATION

Our investigation scope and evidence

Case ID: CSFCL-IA2-2026-005 | Seven files in evidence/acis-portal/

Tag	File	Why it matters
EV-01	lib/struts2-core-2.5.10.jar	Genuine Apache release; carries CVE-2017-5638
EV-02	config/database.properties	Four database passwords in plain text
EV-03	Dockerfile	Specifies root user; secrets in ENV lines
EV-04	config/aws-credentials	Two sets of cloud keys
EV-05	config/acis-backup.pem	Unprotected RSA private key
EV-06	config/.env	Session secret and GitHub token
EV-07	pom.xml	Declares four libraries available before March 2017

Genuine Struts JAR from Maven Central; SHA-1 match: 070e02e9...684b.

Manifest, configuration files and Dockerfile are reconstructed; all credentials and keys are synthetic.

No original Equifax disk image or stolen customer data.

INVESTIGATION QUESTION

What vulnerabilities, exposed credentials and unsafe settings can we identify in the reconstructed evidence, and how do they relate to the documented breach?

06 • THE EXAMINATION

Trivy: examination method and findings

Primary tool: Trivy 0.74.0 — Aqua Security

Examination	Purpose	Recorded findings
JAR vulnerability scan	Identify known vulnerabilities in the compiled library	21 CVEs, including 7 critical; 2 public before 13 May 2017
Dependency manifest scan	Examine libraries declared in pom.xml	88 findings across 4 libraries; 4 public before the intrusion
Secret scan	Find exposed credentials and keys	11 findings in 4 files, 9 critical; 4 database passwords found using custom rules
Configuration scan	Identify unsafe Dockerfile settings	5 failures: root user, secrets in ENV, :latest tag and no HEALTHCHECK
CycloneDX SBOM	Record identified software components	Inventory of identified components

9.8

CVSS 3.1 for CVE-2017-5638; the only critical Struts finding public before 13 May 2017

7/7

Evidence files unchanged; SHA-256 hashes matched before and after

Supporting tools: SHA-256 utilities, Python, grep, unzip

Counts refer to the recorded examination; JAR and manifest findings overlap.

07 • THE EVIDENCE

Evidence preservation and live examination

Entry vulnerability

CVE-2017-5638: remote code execution

**Execution settings**

Dockerfile specifies root (DS-0002)

**Exposed credentials**

Synthetic plaintext database passwords

Correlated risks in reconstructed files; actual exploitation and database access were not tested.

Preserve the evidence

1. Record SHA-256 hashes of all seven files.
2. Execute the examination script.
3. Review findings and file metadata.
4. Compare evidence hashes after examination.
5. Hash and preserve generated outputs.

JAR built: 27 Jan 2017 • Fix released: 7 Mar • Main intrusion: 13 May
The fix was available for **67 days** before the intrusion.

Live terminal demonstration

Open the project root in Shweta's macOS Terminal.

```
bash scripts/run-investigation.sh
shasum -a 256 -c output/latest/evidence-hashes-before.txt
python3 scripts/show-cve.py CVE-2017-5638
```

Then review JAR metadata, secrets, custom rules, configuration, the SBOM and output hashes.

Secret filter: 4 file headings + 11 findings = 15 lines

Before recording

```
command -v trivy; trivy --version; python3 --version
command -v shasum; ls scripts evidence
```

Examination results and Indian legal relevance

Recorded examination results

Examination	Result
Struts JAR	21 vulnerabilities: 7 critical, 10 high, 4 medium
Dependency manifest	88 findings, including 34 critical
Secrets	11 findings across 4 files
Dockerfile	28 tests: 23 passed, 5 failed
SBOM	1 compiled component identified
Evidence integrity	All 7 files matched their baseline hashes

Note: JAR and manifest findings overlap; do not add the totals.
Five Dockerfile failures arise from four distinct checks.

If similar failures occurred in India

IT Act s.43A + SPDI Rules	Security-practice assessment of unpatched software and exposed passwords.
IT Act ss.43, 66, 66C	Potential relevance to unauthorised access and identity misuse; facts and legal conditions matter.
CERT-In Directions 2022	Covered entities: report specified incidents within 6 hours of notice; retain 180 days of ICT logs in India.
CICRA 2005	Credit-information security and privacy obligations.
DPDP Act and Rules: phased commencement	Main duties scheduled for May 2027. Initial breach notice without delay; detailed Board update within 72 hours, unless extended.
Bharatiya Sakshya Adhiniyam s.63	Hashes support integrity; they do not alone establish admissibility.

Academic comparison of hypothetical Indian incident; this scan does not establish legal liability.

Sources: examination report; CERT-In Directions (2022); DPDP Rules and commencement notification (2025).

09 • THE INTERPRETATION

Correlation with the historical case

Our evidence or finding	Connection to the documented case
Vulnerable Struts JAR	Demonstrates detection of the vulnerability used for entry
Plaintext example database credentials	Illustrates the credential exposure described by investigators
Unsafe configuration findings	Demonstrates additional security weaknesses in the reconstructed files
Publication dates and historical timeline	Distinguish findings known before the breach from later discoveries

Our findings illustrate relevant risks; they do not reproduce the actual intrusion.

Recommendations

- Verify urgent patching against the software inventory and SBOM.
- Use Trivy in CI/CD to flag known vulnerabilities before release.
- Store secrets in a vault and run applications with least privilege.
- Segment networks and monitor certificate expiry.

Limitations

- Reconstructed files, not Equifax's original disk.
- CVE detection depends on published data and scanner coverage.
- Custom secret rules detect only patterns they describe.
- Database query controls require separate operational assessment.

Github repo: <https://github.com/Yashvi2874/csfc1-ia2-equifax-trivy-forensics>

10 • CONCLUSION

What our investigation established

- 01 | Vulnerability identified**
Detected the breach-related Struts vulnerability: CVE-2017-5638.
- 02 | Security weaknesses found**
Detected example credentials and unsafe Dockerfile settings.
- 03 | Evidence integrity verified**
All seven evidence files matched their SHA-256 baseline hashes.
- 04 | Findings placed in context**
Linked findings to the historical case while clearly identifying our evidence as a reconstruction.

Main lessons

Verify patches • Restrict access
Protect credentials • Keep monitoring effective